

PROJECT 7 · INDUSTRY-INTEGRATED AI SYNTHESIS

SOC Security Operations Copilot

Rules-first fusion · RAG-grounded summarization · non-bypassable human-approval gate

A 15-minute defense of a system that composes five prior capstone projects — P1 corpus, P2 calibration, P3 rules, P5 prose, P6 governance — into one end-to-end pipeline.

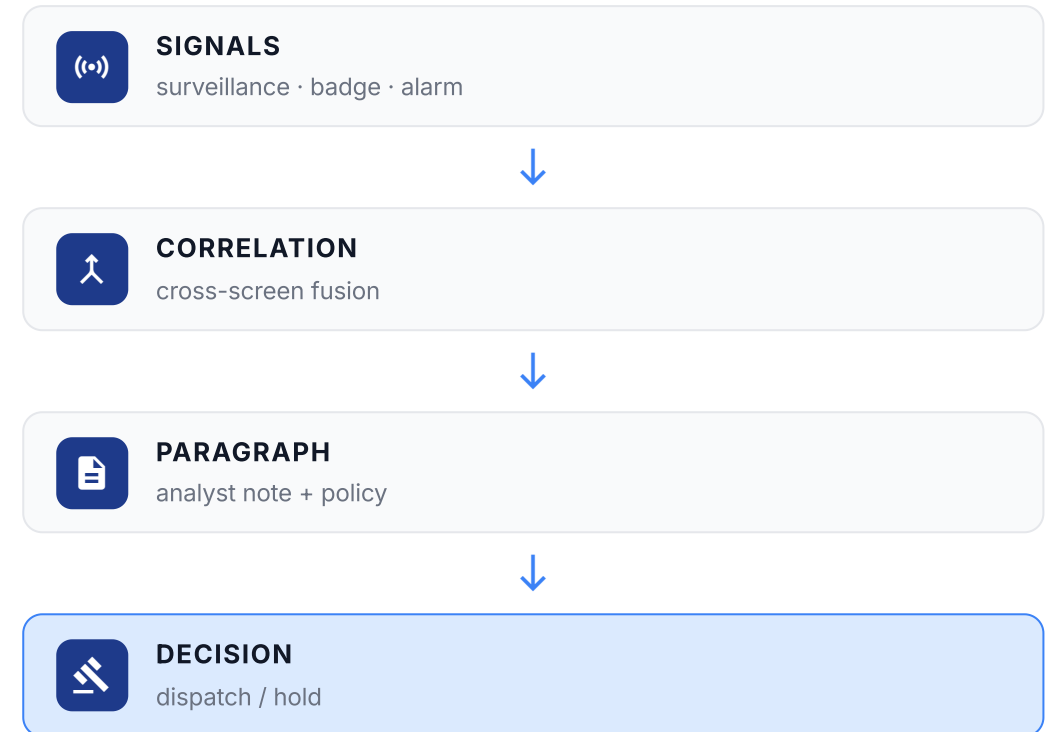


Security operations is a 3 a.m. paragraph-writing job

Why this problem matters, and why AI is the right tool

- SOC teams fuse surveillance feeds, badge-access logs, and alarm streams — thousands of events per site per day.
- Cross-screen correlation is the hard task: a tailgate + forced door is invisible to either screen alone.
- The 3 a.m. operator reads the fused signal, matches it to policy, writes the analyst paragraph, and decides whether to dispatch.

Today's tools give raw streams. The paragraph-writing and policy-matching is what's automatable — the call is not.



WHY AI FITS

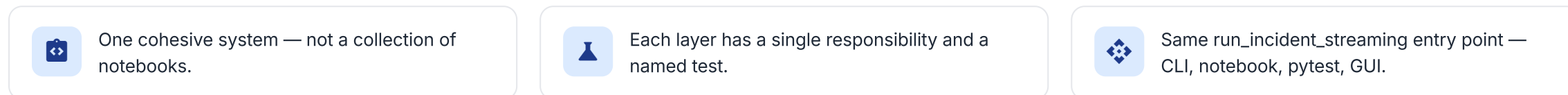
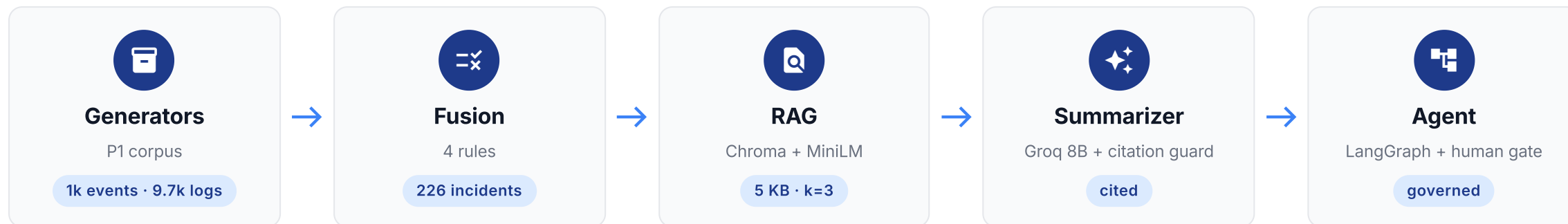
Deterministic fusion

Grounded summaries

Human-in-loop

Five subsystems compose one end-to-end pipeline

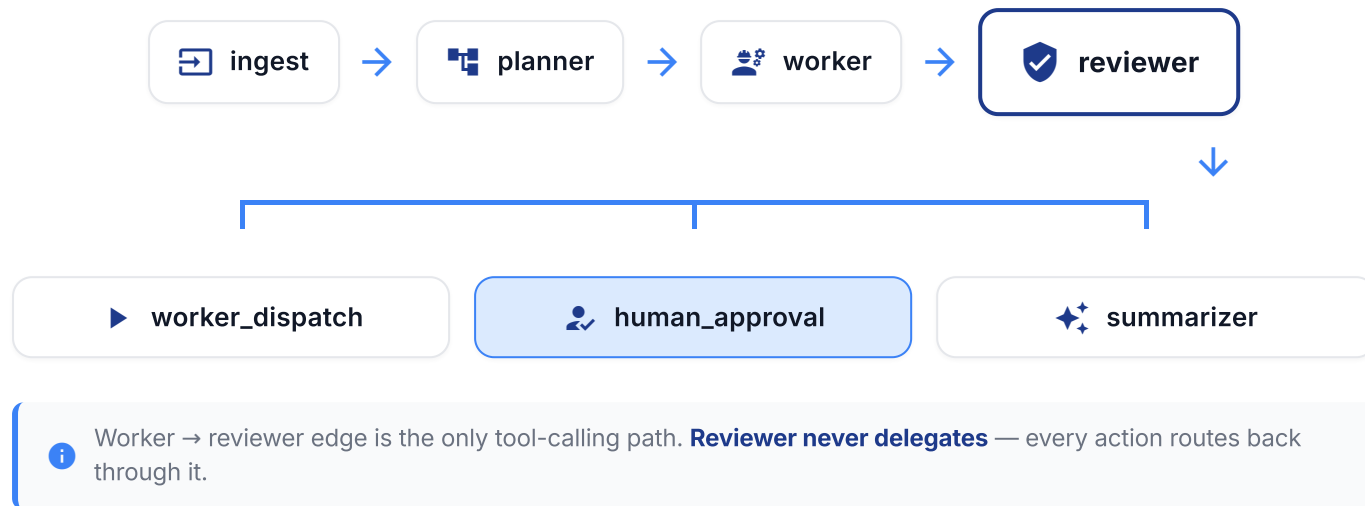
Each layer is small, swappable, and tested



KEY PROMISE: GROUNDED SUMMARIES + HUMAN APPROVAL

The LangGraph governance topology

Compiled view of the agent the rubric submission notebook runs



THE NON-BYPASSABLE GATE

The reviewer is the only policy gate in the system.

Every action routes through the reviewer. The worker never calls a tool directly — that edge is the non-bypassable guarantee.

The gate is reused from P6, not rewritten. Two documented edits: a plan-loop dispatch fix and de-labeled docstrings.

🚫 `case.close` → BLOCKED

🚫 `incident.escalate` → HUMAN + risk≥80

Five prior projects, one system

P1 data · P2 calibration · P3 rules · P5 prose · P6 governance

PROJECT	WHAT IT CONTRIBUTED	EVIDENCE
 P1 — Reproducible workflows	The full corpus the copilot runs on (1k events / 9.7k logs / 3 sites); schema-adapter normalizes it.	<code>src/generators/p1_pipeline.py</code> · <code>src/utils/p1_adapter.py</code>
 P2 — Statistical analysis	The 0.85 threshold as a contract, not a constant. Chi-square + t-test re-run on the copilot slice.	<code>tests/test_threshold_calibration.py</code>
 P3 — Applied ML	Rules-first discipline + leakage-audit lesson. Fusion layer is rules-only; future ML must split by site + contiguous time_window.	<code>src/fusion/rules.py</code> · <code>src/fusion/risk_scorer.py</code>
 P5 — Generative AI	Genre reference for analyst-voice prose (NIST SP 800-61 / CSIRT / CERT). Summarizer is a citation-grounded LLM call, not the P5 model.	<code>src/agent/summarizer.py</code>
 P6 — Agentic AI	The LangGraph governance spine, lifted and adapted (one plan-loop fix). Non-bypassable gate hard-blocks case.close and gates incident.escalate.	<code>src/governance/</code> · <code>src/domain/</code>

🔗 Removing any one of these layers breaks a real capability — fusion, policy routing, grounded summaries, or the non-bypassable escalation gate.

Three decisions that shaped the system

Each one is a tradeoff, with the alternative explicit

**Rules-first fusion, not an ML scorer**

CHOICE

Per-rule base + size/confidence bonus, capped at 100.
Firing rule recorded on every incident.

ALTERNATIVE

A learned scorer.

TRADEOFF

Auditable now; an ML scorer would learn patterns the rules miss but be opaque. ML is a swap-in behind risk_scorer.py.

 recall@0.85 = 58%

**Chroma + MiniLM, not a hosted vector DB**

CHOICE

5-doc KB, in-process, 384-dim normalized cosine.
Category routing boosts matching category by 0.3 before MMR.

ALTERNATIVE

A hosted vector DB.

TRADEOFF

~3s model load on first call vs. monthly bill, API key, network dependency. BM25 + cross-encoder is the next step, not a bigger stack today.

 5 KB · in-process

**Citation guard on a free 8B model**

CHOICE

Parse KB-XXXXX from output, keep only retrieved ids, retry once with stricter prompt, else mark needs_review.

ALTERNATIVE

A bigger model.

TRADEOFF

~1 in 50 incidents pays one extra Groq call; hallucinated policy citations are impossible, not just unlikely.

 ~1 in 50 retry

I chose transparency and auditability over recall.

Ethics, made concrete in the system

Not a footnote — a code path, a test, a UI button

RISK	WHY IT MATTERS	WHAT THE SYSTEM DOES
 Misuse / fabricated authority	Surveillance + access data is sensitive; a model that invents a policy justification is the worst failure mode.	Citation guard (summarizer.py): KB-XXXXXX must be in retrieved set, else needs_review.
 Accountability / auto-escalation	Escalation is irreversible — it dispatches security, suspends badges.	case.close hard-blocked; incident.escalate requires human approval at risk_band_score ≥ 80.
 Transparency	Every incident must be traceable to a rule, a score, and a citation.	Per-rule provenance (_rule); raw cosine score returned; hash-chained audit log.
 Calibration honesty	A rule with a 42% anomaly blind spot is a deployed lie unless surfaced.	P2's recall@0.85 = 58% asserted in test_threshold_calibration.py; GUI shows raw numbers.

THE NON-BYPASSABLE GATE

P6 · REUSED



HUMAN REQUIRED

No auto-approve. No auto-escalate. No auto-close.

app.py line 639 — Grant/Deny button

The system recommends and surfaces. The operator keeps judgment, override, and accountability.

What worked, what didn't, what's known to be wrong

Strengths are real; limitations are surfaced, not hidden

 STRENGTHS WHAT WORKED	 LIMITATIONS & RISKS SURFACED, NOT HIDDEN
• Notebook: Restart & Run All clean across 30 cells. • Tests: 34/34 green across 5 files. • RAG self-check: every incident_type routes to its matching KB doc at rank 1. • Summarizer: 4/4 spot-check incidents cite correct policy; 0 needs_review. • One entry <code>run_incident_streaming</code> — powers CLI, notebook, point — <code>pytest</code>, GUI.	• Fusion <code>recall@0.85 = 58%</code> — P2 hard finding; surfaced to operators, not hidden. • Free 8B model occasionally invents kwarg names — handled by arg-filtering wrapper. • Audit log carries an unrepaired break at an early sequence number; GUI shows the warning honestly. • Data is P1 synthetic corpus, not a real SOC environment. • Streamlit GUI is local-only; no auth; per-session <code>data/uploads/{uuid}/</code> . uploads under



HARD FINDING — The 0.85 threshold misses ~42% of anomaly events. Documented; not a deployable claim.

What this shows about the work, and what's next

System-level thinking · responsible engineering · reuse with discipline

A WHAT THIS DEMONSTRATES

READINESS SIGNALS



System-level thinking — five projects compose into one pipeline.



Responsible engineering under constraints — free-tier + 5-doc KB + \$0 → category routing, citation guard, arg filtering.



Reuse with discipline — governance spine lifted, fixed, de-labeled, guarded by a no-domain-imports test.



Defensible defaults — every metric is asserted in a test, not in prose.

B NEXT STEPS · 12-18 MONTHS

THREE PHASES

NOW

⚡

0 – 3 MONTHS

- Address the 58% recall finding: lower threshold or add a complementary low-confidence rule.
- Real auth for the Streamlit GUI — reverse proxy + OAuth.

→

NEXT

🌐

3 – 9 MONTHS

- Multi-vendor event-stream connectors (P1 corpus is synthetic).
- Retrieval-level eval — 10-row golden set + hit@k, before any model swap.

→

LATER

🚀

9 – 18 MONTHS

- Hybrid retrieval — BM25 + cross-encoder when KB grows past ~100 docs.
- Optional hosted vector DB once network dependency is justified.

Three questions I expect — and the short answer

If you only have 30 seconds for each, here they are

Q.

01

Why rules-first, not an ML scorer?

A.

Auditability. Every incident carries the firing rule. The ML scorer is a swap-in behind the same `risk_scorer.py` interface when the rule layer earns its keep — and the P2 calibration test confirms the cost honestly.

recall@0.85 = 58%

Q.

02

What would break in production?

A.

The Streamlit GUI has no auth (dev tool); the audit chain has an unrepaired early break; the fusion threshold misses ~42% of anomaly events. Each is a known and tested boundary, not a hidden risk.

3 known boundaries

Q.

03

Why is your RAG just dense + MMR, not hybrid?

A.

The KB is 5 documents. BM25, a cross-encoder, and a query-rewrite LLM are the right next step when the KB grows past a few hundred docs, not today. Category routing fixes shared-vocabulary mis-ranking cheaply at this scale.

5 KB docs

*"The copilot doesn't replace the operator. It replaces the part of the shift that's a **typist**, a **log-stitcher**, and a **3 a.m. paragraph-writer**."*